Individuazione degli utenti MySQL
su Metasploitable

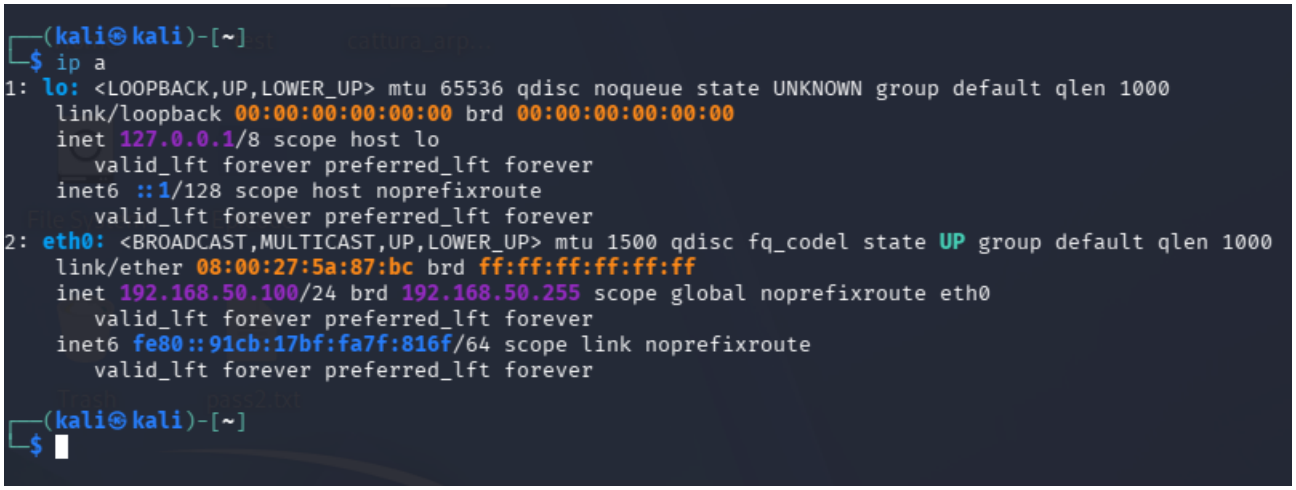
Esercitazione pratica con Kali Linux, Nmap e client MySQL

Obiettivo della pratica

L'obiettivo dell'esercitazione era ottenere la lista degli utenti MySQL presenti sulla macchina Metasploitable. Per svolgere la verifica ho utilizzato Kali Linux come macchina di analisi e Metasploitable come sistema target, entrambe avviate in VirtualBox e collegate alla rete interna denominata intnet.

La traccia suggeriva due strumenti: lo script Nmap mysql-brute e il client MySQL. Ho quindi verificato prima la connettività e il servizio sulla porta 3306, poi ho utilizzato Nmap per individuare credenziali di accesso e infine il client MySQL per interrogare la tabella degli account.

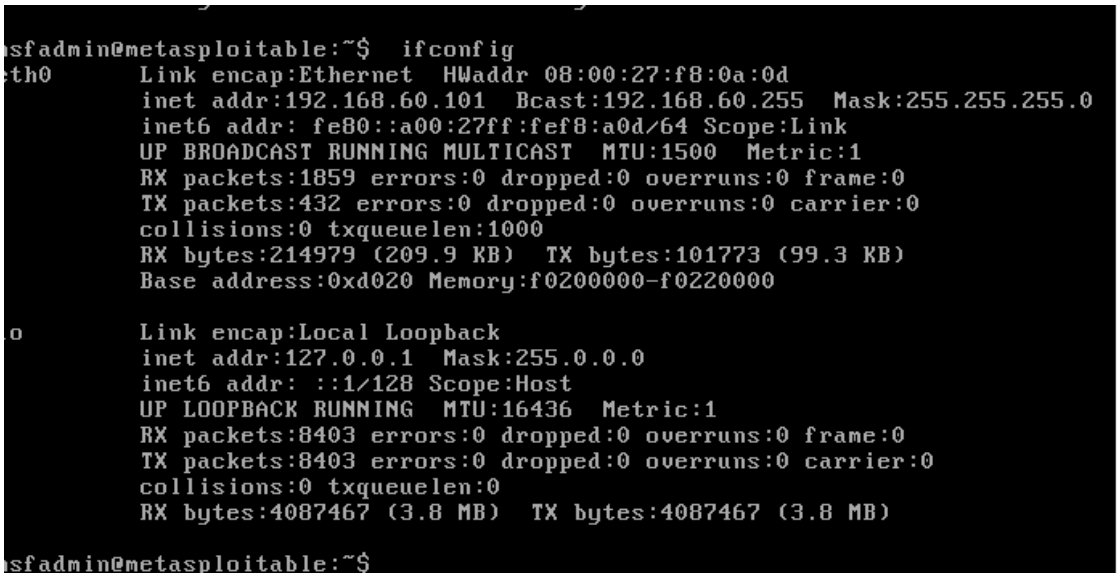
Verifica dell'indirizzo IP di Kali



Configurazione IP di Kali Linux.

Per iniziare ho controllato la configurazione di rete di Kali con il comando ip a. Dall'output ho individuato l'interfaccia eth0 attiva e l'indirizzo 192.168.50.100/24. Questo è l'indirizzo della macchina da cui ho eseguito le scansioni e i collegamenti verso Metasploitable.

Verifica dell'indirizzo IP iniziale di Metasploitable



Configurazione iniziale di Metasploitable.

Successivamente ho controllato la macchina Metasploitable con ifconfig. Inizialmente la sua interfaccia eth0 aveva l'indirizzo 192.168.60.100/24. Ho quindi notato che Kali e Metasploitable, pur essendo collegate alla stessa Internal Network intnet di VirtualBox, avevano indirizzi appartenenti a due sottoreti differenti.

Controllo della tabella di routing di Kali

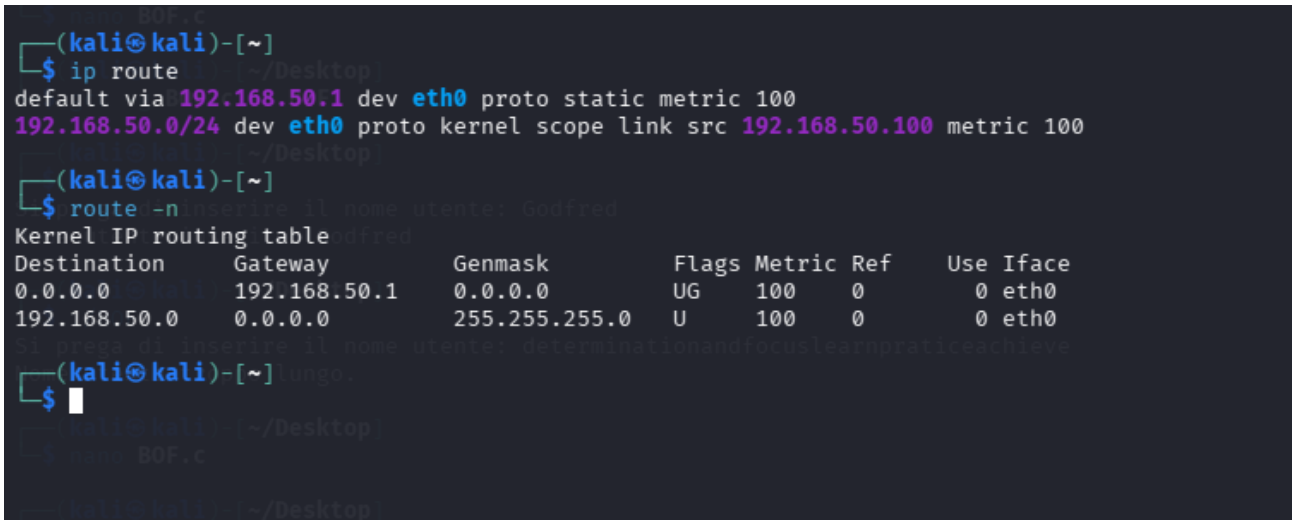


Tabella di routing di Kali Linux.

Ho eseguito ip route e route -n per verificare il percorso di rete configurato su Kali. L'output conferma la rete direttamente collegata 192.168.50.0/24 sull'interfaccia eth0 e il gateway 192.168.50.1.

Controllo della tabella di routing di Metasploitable

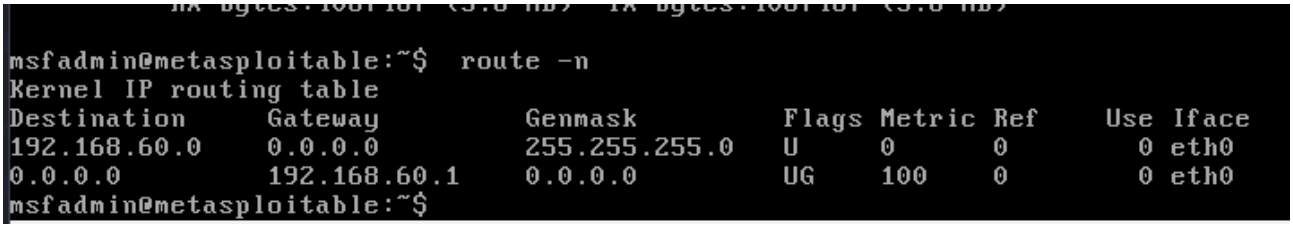
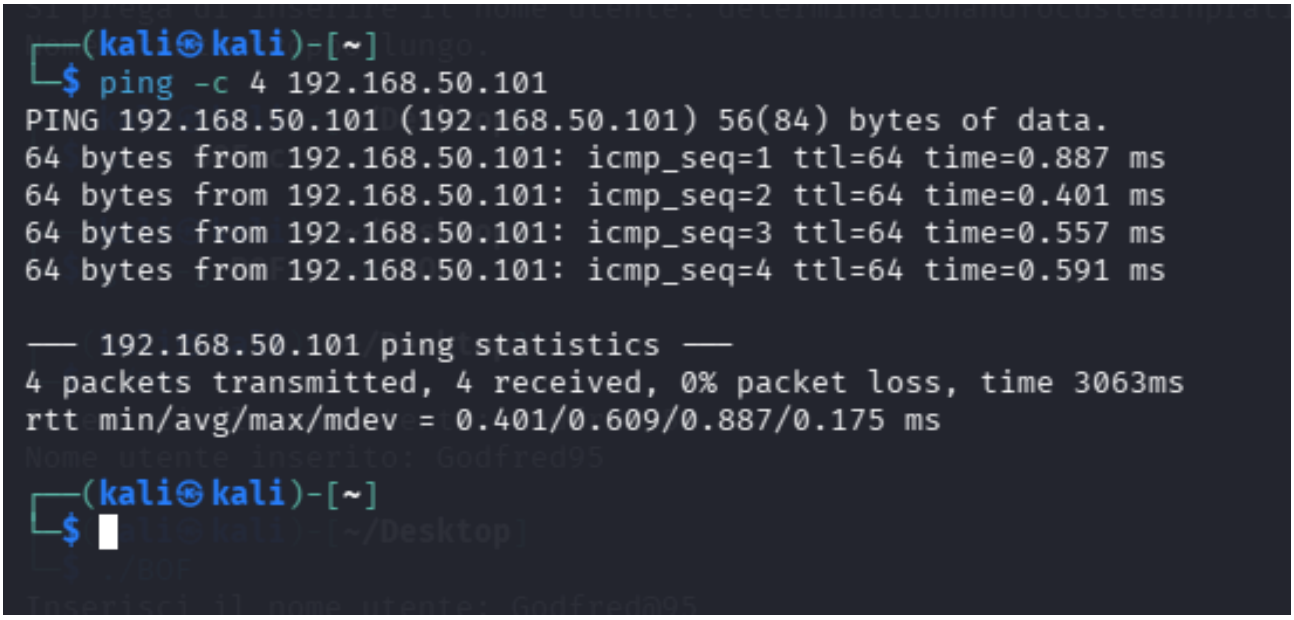


Tabella di routing di Metasploitable.

Ho controllato anche la tabella di routing di Metasploitable con route -n. La rete locale risultava 192.168.60.0/24 e il gateway configurato era 192.168.60.1. Per poter effettuare il test direttamente sulla stessa sottorete di Kali, ho temporaneamente assegnato a Metasploitable l'indirizzo 192.168.50.101/24, mantenendo il collegamento alla rete intnet.

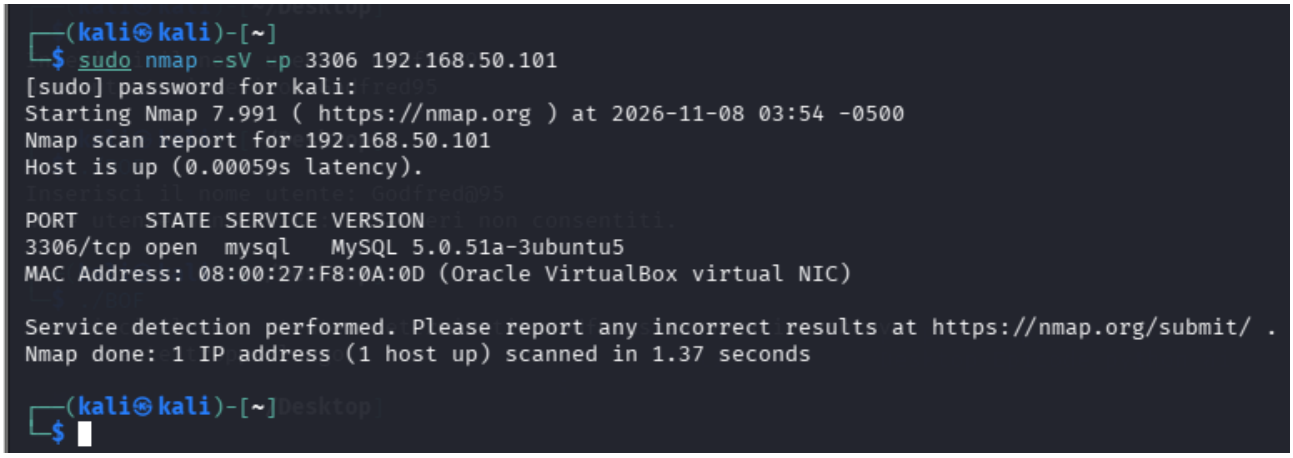
Verifica della comunicazione tra le due macchine



Test ping da Kali verso Metasploitable.

Dopo la modifica temporanea dell'indirizzo IP di Metasploitable, da Kali ho eseguito un ping verso 192.168.50.101. Il test ha avuto esito positivo: sono stati trasmessi quattro pacchetti e ne sono stati ricevuti quattro, con una perdita dello 0%. Questo risultato ha confermato la comunicazione tra le due VM.

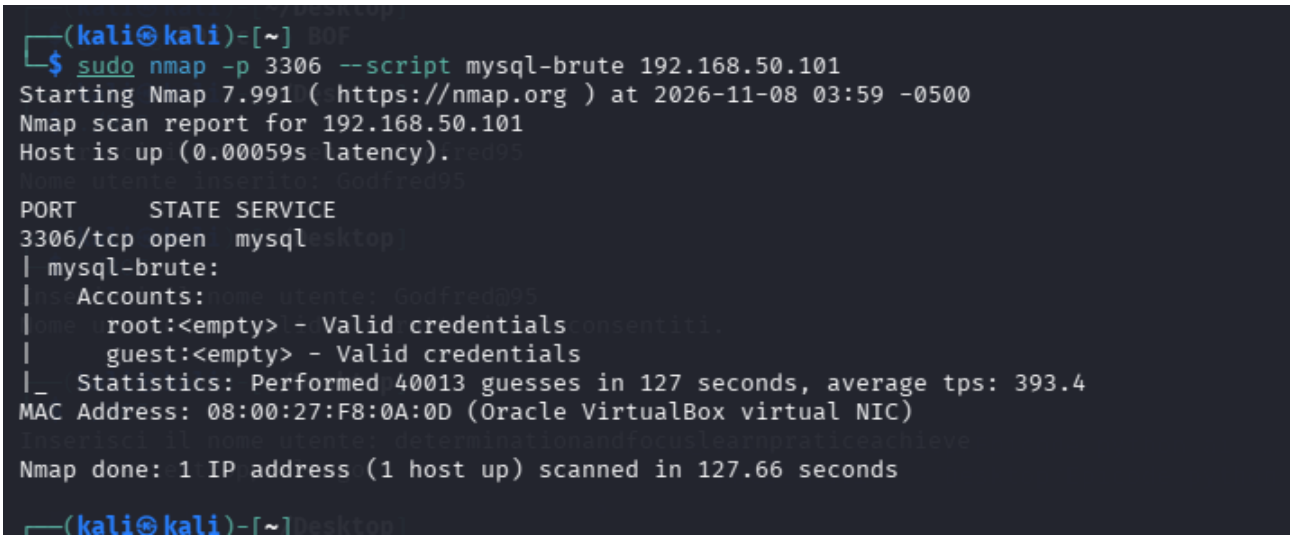
Scansione della porta 3306 e identificazione del servizio



Scansione Nmap della porta TCP 3306.

Una volta verificata la connettività, ho eseguito una scansione mirata con Nmap per controllare la porta predefinita di MySQL. Il risultato mostra la porta 3306/tcp aperta e identifica il servizio come MySQL, con versione 5.0.51a-3ubuntu5. A questo punto ho avuto conferma che il servizio database era raggiungibile dal sistema Kali.

Esecuzione dello script mysql-brute



Risultato dello script Nmap mysql-brute.

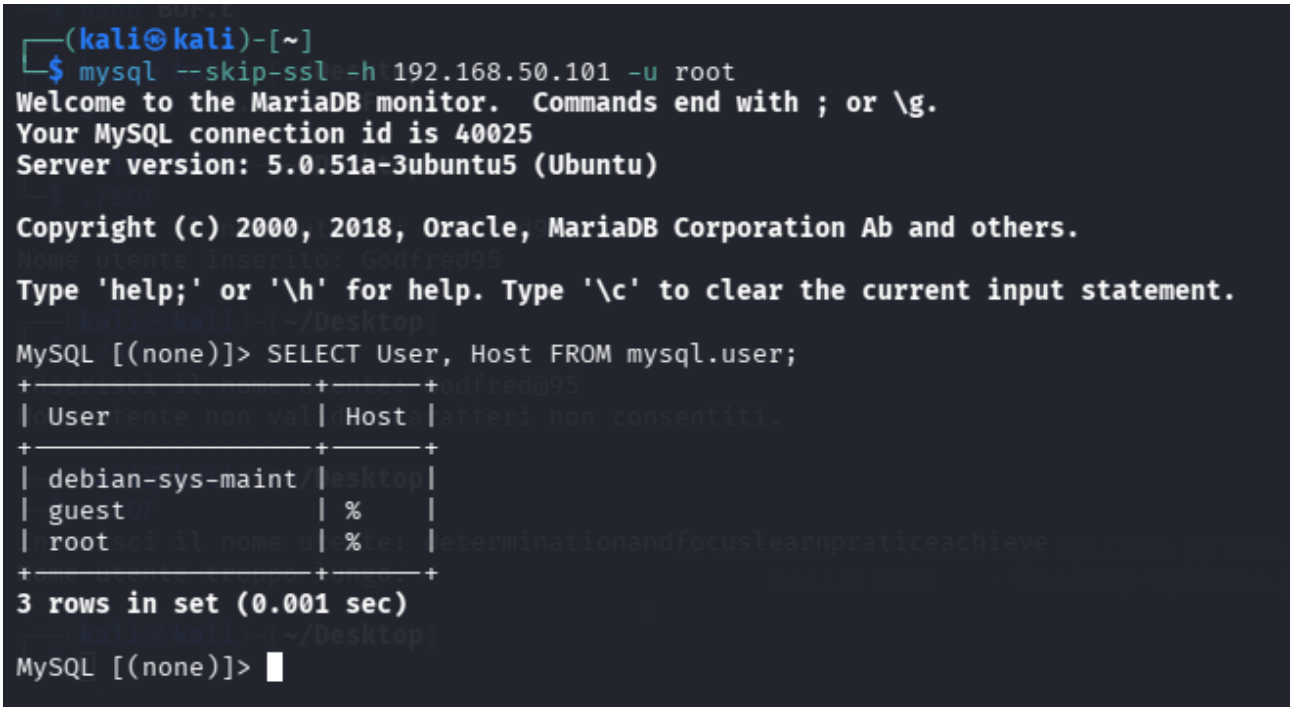
In seguito ho utilizzato lo script mysql-brute suggerito dalla traccia. Lo script ha individuato due account per i quali l'autenticazione è risultata valida: root con password vuota e guest con password vuota. L'output riporta 40.013 tentativi complessivi e una durata di circa 127 secondi. Questo passaggio mi ha fornito credenziali valide da verificare con il client MySQL. La password vuota indica che

l'account non richiede una password per questa autenticazione; non significa che Nmap abbia recuperato una password in chiaro.

Primo tentativo di connessione e problema TLS/SSL

Dopo la scansione ho provato a collegarmi al server utilizzando l'account root. Il primo tentativo non è andato a buon fine e il client ha restituito "ERROR 2026 (HY000): TLS/SSL error: wrong version number". Ho interpretato il problema come un'incompatibilità nella negoziazione TLS/SSL tra il client presente su Kali e la vecchia versione del server database installato su Metasploitable. Non ho considerato questo errore come un problema delle credenziali, perché lo script Nmap aveva già indicato un'autenticazione valida.

Connessione al database disabilitando SSL per il test



Connessione riuscita e interrogazione della tabella mysql.user.

Per superare l'incompatibilità ho ripetuto il collegamento disabilitando SSL per questa specifica connessione al server di laboratorio. Il client ha confermato l'accesso a MariaDB, versione 5.0.51a-3ubuntu5. Una volta ottenuto il prompt MySQL, ho eseguito la query sulla tabella mysql.user per visualizzare gli account registrati. Il risultato ha restituito tre righe: debian-sys-maint associato a localhost, guest associato a % e root associato a %.

Il simbolo % nella colonna Host è un carattere jolly che può corrispondere a host diversi. La possibilità effettiva di collegarsi da remoto dipende comunque dalle regole di autenticazione, dalla configurazione del servizio e dai controlli di rete.

Verifica della versione del server e dei privilegi dell'account



Versione del server e privilegi dell'utente corrente.

Per completare l'analisi ho eseguito SELECT VERSION() e SHOW GRANTS FOR CURRENT_USER. La prima query ha confermato la versione 5.0.51a-3ubuntu5. La seconda ha mostrato che l'account utilizzato è root e che dispone di GRANT ALL PRIVILEGES ON *.* WITH GRANT OPTION. In pratica, l'account ha privilegi amministrativi su tutti i database e può concedere privilegi anche ad altri account.

Considerazioni e possibili misure di remediation

L'esercitazione ha evidenziato una configurazione MySQL molto permissiva. In particolare, sono stati individuati account con password vuota e un account root accessibile da host diversi da localhost, con privilegi amministrativi completi. Questa configurazione aumenta il rischio che un soggetto non autorizzato possa accedere al database, soprattutto se il servizio è esposto su una rete non adeguatamente segmentata.

Le principali misure di correzione che proporrei sono:

- assegnare password robuste e univoche a tutti gli account che devono essere mantenuti;
- rimuovere o disabilitare gli account non necessari, compreso guest se non richiesto;

- limitare l'account root alle connessioni locali o a host amministrativi strettamente autorizzati;
- applicare il principio del minimo privilegio, evitando GRANT ALL PRIVILEGES quando non necessario;
- limitare l'accesso alla porta TCP 3306 tramite firewall e segmentazione di rete;
- aggiornare il server database a una versione supportata e mantenuta, dopo aver verificato la compatibilità delle applicazioni.

Conclusione

Con questa esercitazione sono riuscito a raggiungere l'obiettivo richiesto ottenere la lista degli utenti MySQL presenti su Metasploitable. Dopo aver verificato la rete e individuato il servizio sulla porta 3306, ho utilizzato Nmap con lo script mysql-brute per individuare credenziali valide. In seguito mi sono collegato al database con il client MySQL, risolvendo il problema di compatibilità TLS/SSL tramite l'opzione --skip-ssl, e ho interrogato la tabella mysql.user. Ho identificato tre account e ho verificato la versione del server e i privilegi dell'account root. I risultati sono stati documentati con gli screenshot inseriti nelle rispettive fasi della relazione.